

Атаки, направленные на похищение учётных данных

Андрей Камардин

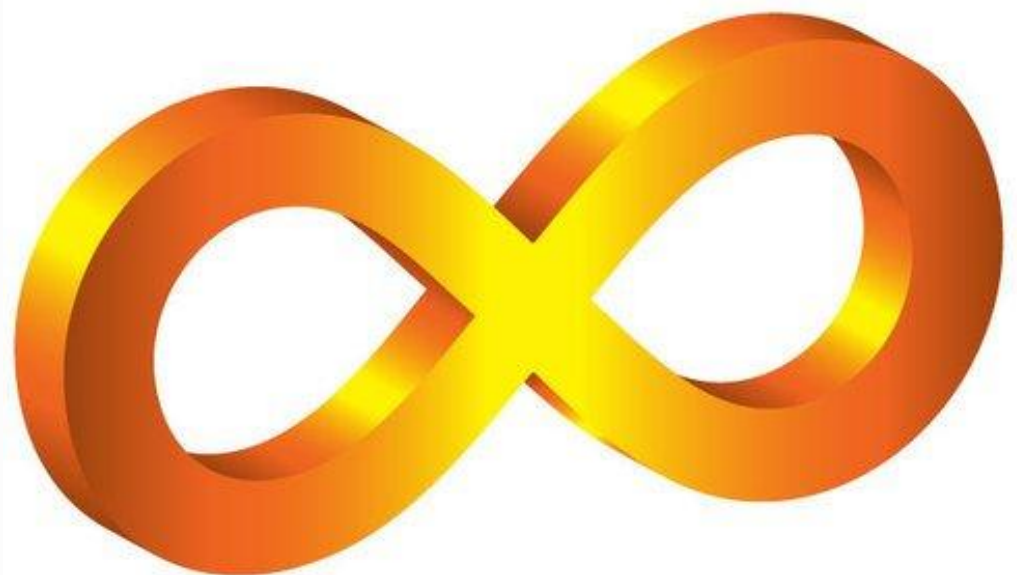
Системный администратор, консультант
по внедрению серверных ОС

Стратегии защиты учётных данных

- Спланируйте проникновение
- Создайте портфель решений безопасности
- План по достижению компромисса

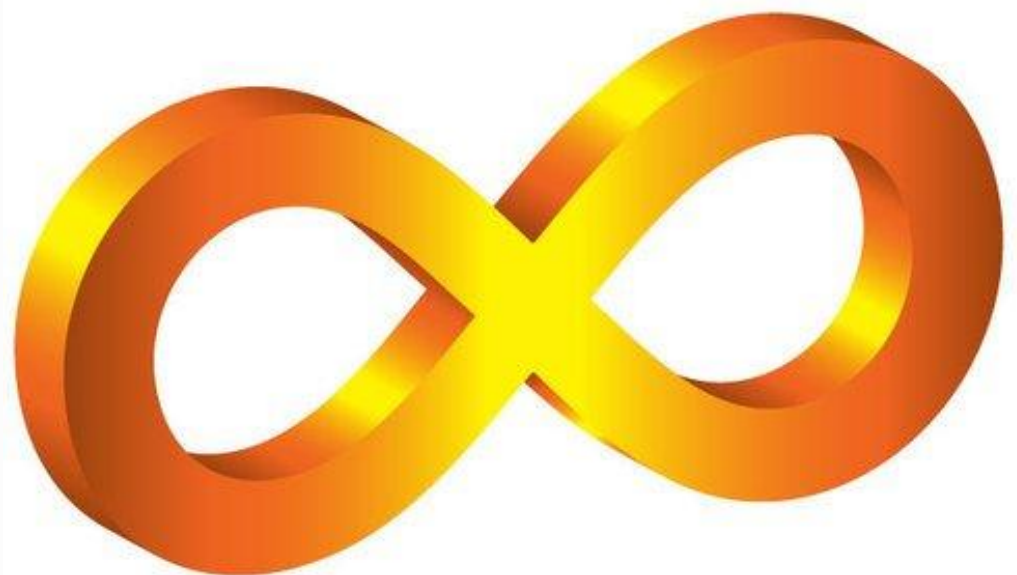
Стратегии защиты учётных данных

- Идентифицировать
- Защитить
- Выявить
- Отреагировать
- Восстановить



Атаки, направленные на похищение учётных данных

- Pass the hash
- Kerberos pass the ticket
- Kerberos golden ticket and silver ticket
- Key loggers
- Shoulder surfing



Стратегии защиты учётных данных

- **Думайте как атакующий:**

Что мне нужно атаковать и скомпрометировать в первую очередь?

- **Приоритет на ценные учётные записи и компьютеры:**

Компьютеры топ-менеджмента, хранилища обновлений, сканеры безопасности, учётные записи администраторов домена, учётные записи резервного копирования

Стратегии защиты учётных данных

- **Идентифицируйте нормальное поведение:**

Какие ресурсы используются для работы, кто получает к ним доступ?

- **Защита от известных и новых угроз:**

Ослабление рисков известных угроз и внедрение безопасных практик и цифровой гигиены для снижения вреда от угроз в будущем

Стратегии защиты учётных данных

Уровни доступа:

- Уровень 0: администраторы домена, контроллеров домена
- Уровень 1: администраторы серверов
- Уровень 2: администраторы рабочих станций

Стратегии защиты учётных данных

Административные хосты:

- Выделенное устройство для физического входа
- Jump-сервер для выполнения административных задач и инструментов
- Сервера с недоступным RDP, PSR
- Сервера с доступным RPD, PSR

Стратегии защиты учётных данных

Создание административных хостов:

- Все носители чистые и не заражены вредоносным ПО
- Соответствие требованиям безопасности
- Ограничения на запуск в UEFI (Measured Boot, Secure Boot)
- Контроль приложений (AppLocker)
- Полнодисковое шифрование

Стратегии защиты учётных данных

Создание административных хостов:

- Ограничение использования USB-устройств
- Сетевая изоляция — доступ извне только для доверенных соединений
- Безопасность на базе виртуализации
- Антивирусное ПО
- Анализ поверхности атаки

Обучение пользователей, ведение журналов аудита пользователей